

SOC Logging & Analysis

Alexis Ahmed

Red & Blue Team Instructor @INE

Red Team Lead @HackerSploit

Key Concepts

- + Logging Fundamentals
- + Event Analysis
- + SIEM Fundamentals

MAJOR TOPICS

- + Introduction To Logging
- + The Logging Lifecycle
- + Collecting & Shipping Logs
- + SIEM Fundamentals
- + Log Analysis
- + Alerting



LEARNING OUTCOMES

- + Understand the need for logs and what they provide
- + Understand where logs originate and how to collect them
- + Be able to effectively interpret and analyze simple logs
- + Properly understand and navigate a SIEM
- + Understand alerts and the alerting lifecycle
- + Be able to combat alert fatigue and other challenges

PREREQUISITES

- + Understanding of basic SOC terminology
- + Basic cybersecurity fundamentals
- + Basic IT/networking fundamentals



LET'S GET STARTED!



Logging Introduction



Logging Introduction

What is Logging?

Logging refers to the ***automatic recording*** of ***system and application events*** that occur on a device, server, or network.

These logs are generated by operating systems, applications, and network devices to capture details about activities, errors, requests, and behaviors.

What is Logging?

- Record of activity on a system or device
 - Server, workstation, network equipment, etc
- Firewall blocking a network connection
 - Source/destination, port/protocol, packet contents
- User logging into workstation
 - Username, system used
- File opened and modified
 - Username, file/path, type of access, activity, source
- Who, what, when, where

Why Logging Exists

- + **Logging** plays a critical role in system administration, troubleshooting, and security operations. Its primary purposes include:
 - + Auditing: Track user actions and system changes for accountability
 - + Troubleshooting: Diagnose software or hardware failures
 - + Behavior Monitoring: Understand normal vs. anomalous activity
 - + Security Monitoring: Detect unauthorized access or malicious activity
 - + Compliance: Meet regulatory requirements (e.g., HIPAA, PCI-DSS)

Without logs, detecting incidents and understanding their root cause would be nearly impossible.

Logging is Critical

- Proper logging is critically important for security
- Logs can assist in identifying:
 - Port scans
 - Brute force attacks
 - DoS attacks
 - Account compromises
 - System errors
 - Almost any type of security issue
- Can be used for real-time reporting & alerting
- Historical and forensic data

Logs in the SOC

- Feed into SIEM (Security Information & Event Management) & other detection systems
- Analyst usage
 - Initial triage
 - Investigation
 - Response
 - Remediation
 - Reporting
- Foundation for everything else in the SOC

Thank You!

Log Sources & Types



Log Sources & Types

Access Logs

- **Goal: Identify who attempts to access what, from where, and when**
- All systems and devices connected to the network
- Successful or unsuccessful attempts

Account information	username, name, type of account
Failed or successful	
Source of access attempt	device name, IP
Access destination or type	server name, fileshare
Type of access requested/granted	read, write, etc
Date & time	always required

Network Logs

- These are Logs that are generated by network infrastructure and monitoring tools that provide visibility into traffic between systems.
- **Goal: Analyze all inbound and outbound network traffic and associated devices**
- Common Sources:
 - Firewall Logs (allow/deny rules, NAT activity)
 - Intrusion Detection/Prevention Systems (IDS/IPS) (e.g., Snort, Suricata)
 - NetFlow/IPFIX (summarized metadata about network flows)
 - Packet Captures (PCAPs) (full traffic inspection)
 - VPN, DHCP, DNS, and Proxy Logs

Network Logs

Source & destination information	IP, port, country, geolocation, etc
Type of traffic	Protocol, other specifics
Application layer information	If available
Rule matches	Typically firewalls, IPS, etc
Common uses	Web traffic, domain lookups

Security Control Logs

- **Goal: Identify actions and classify effectiveness of all security controls**
- Includes devices like firewall, IPS, DLP - any device dedicated to security

Type of control	Specific device type (IPS, VPN, SIEM, etc)
Source & destination information	Including impacted device/user (may vary by entry)
Action taken	Blocked, alerted, none, manual action, etc
Decision points	Why was action taken, how was decision reached?
Triggered rule	Information on specific rule data

Operating System Logs

- These are Logs that are generated by individual systems or devices such as workstations, servers, laptops, and mobile devices.
- **Goal: Identify system-level events and others**
- Useful information:
 - Windows
 - Security logs (logins, privileged use, etc)
 - System (services, devices)
 - Application (various software events)
 - Linux journal/syslog
 - Auth logs, service/kernel logs

Storage/File Server Logs

- **Goal: Accurately identify & track all access to any files & file shares**
- Applies to cloud and local storage
- Should include any back up systems
- Useful information:
 - User accessing
 - What was accessed (full filename and path)
 - Access attempt result (success/fail)
 - If failed - why
 - Type of access (read-only, modify, create, delete, etc)
 - Additional alerting for “unusual” access activities
 - Potentially indicating malware/ransomware

Other Log Sources

- Application Logs
 - Web servers
 - Databases
 - Email systems
- Cloud services
 - AWS, Azure, GCP, etc
- OT/IoT devices
 - Common manufacturing, critical infrastructure, healthcare, etc
- Physical security systems
 - Badge access, camera systems

How These Sources Work Together (Correlation)

Effective incident detection and analysis depend on correlating data across these sources for full visibility and context.

Log Source Type	Example Use Case
Operating System	Identify malware executed on a workstation
Network	Detect outbound traffic to a known malicious IP
Access/Application	Trace user login from an unusual location or time

Thank You!

Windows Event Logging

Windows Event Logging

Windows Event Logging is a ***built-in*** mechanism used by the **Microsoft Windows** operating system to ***record*** and ***store*** information about ***system activity***, ***application behavior***, ***security events***, and other operating system operations.

These logs are a critical component for system auditing, troubleshooting, and security monitoring.



How Logging Works on Windows

How Logging Works on Windows

1 - Event Generation

- + Whenever an ***action occurs*** on the system (e.g., a user logs in, a service starts, a file is modified), Windows generates an event.

This event includes:

- + A unique Event ID
- + A timestamp
- + The source (e.g., *Microsoft-Windows-Security-Auditing*)
- + A severity level (*Information, Warning, Error, Critical*)
- + Event data (user account, process, file path, IP address, etc.)

How Logging Works on Windows

2 - Event Logging Service

- + The Windows Event Log service (*eventlog*) captures these events and writes them to structured log files stored in the **.evtx** format in the system directory:

```
C:\Windows\System32\winevt\Logs\
```

How Logging Works on Windows

3 - Storage & Retention

- + Each log type (Security, System, Application, etc.) is stored in a separate **.evtx** file.
- + These logs can be rotated, archived, or overwritten based on configured settings (size, retention policy, etc.).

How Logging Works on Windows

4 - Accessing Logs

- + Logs can be viewed using:
 - + Event Viewer GUI (`eventvwr.msc`)
 - + PowerShell commands (e.g., `Get-WinEvent`, `Get-EventLog`)
 - + Command Line tools (e.g., `wevtutil`)
 - + SIEM solutions (e.g., logs shipped to Splunk, ELK)



Types of Windows Event Logs

Types of Windows Event Logs

1 - Security Logs

- + Related to system access, login/logout activity, account management, privilege use
- + Controlled via audit policies.
- + Managed by the **Security Auditing** subsystem.
- + Common Event IDs:
 - + 4624 – Successful logon
 - + 4625 – Failed logon
 - + 4670 – Permissions on object changed
 - + 4688 – Process created

Types of Windows Event Logs

2 - System Logs

- + Events logged by Windows system components and drivers (e.g., kernel, drivers, services)
- + Useful for troubleshooting hardware or OS-level issues
- + Common Event Sources: Service Control Manager, Ntfs, Kernel-General

Types of Windows Event Logs

3 - Application Logs

- + Events written by user-mode applications
- + May contain error messages, failures, warnings, or custom application logging
- + Example sources: MExchange, .NET Runtime, SQLServer

4 - Setup Logs

- + Installation-related logs, including Windows Updates or system setup components

Types of Windows Event Logs

5 - Forwarded Events

- + Centralized collection of events from remote Windows systems
- + Requires Windows Event Forwarding (WEF) and a configured subscription manager

Types of Windows Event Logs

6 - Additional Logs (via Microsoft or 3rd Party Tools)

- + Sysmon Logs – Deep process, network, and driver monitoring (via Sysinternals Sysmon)
- + Windows Defender Logs
- + PowerShell Operational Logs
- + Terminal Services Logs



Use Cases For SOC Analysts

Use Cases For SOC Analysts

- + User Behavior Monitoring: Login patterns, unauthorized access.
- + Process Tracking: Suspicious or unexpected program execution.
- + Privilege Abuse Detection: Admin group changes, token abuse.
- + Lateral Movement Tracing: Remote access via RDP, WinRM.
- + Persistence Mechanism Discovery: Scheduled tasks, service installation.

Thank You!

Linux Logging

Linux Logging Explained

Linux logging refers to the process by which Linux-based systems *record events, messages, and system activity*.

These logs are **essential** for system administration, troubleshooting, performance monitoring, and security analysis.

Linux relies on a combination of text-based log files, logging daemons, and kernel-level messages to capture and store logs.



How Logging Works on Linux

How Logging Works on Linux

1 - Event Generation

- + Whenever a system component, application, or user action occurs, ***an event message*** is generated.
- + These events can be:
 - + System-level messages (e.g., service start/stop, kernel messages)
 - + Application output (e.g., errors, access logs)
 - + Security-related activity (e.g., login attempts)

How Logging Works on Linux

2 - Logging Daemons

- + The logging system routes and stores these events using logging daemons, including:
 - + **rsyslog** (default on most modern distros)
 - + **syslog-ng**
 - + **journald** (used by systemd-based systems)
- + These daemons handle:
 - + Message formatting
 - + Priority/severity tagging
 - + Routing to files, remote servers, or other logging systems

How Logging Works on Linux

3 - Storage & Formatting

- + Logs are stored as plain text files under the `/var/log/` directory.

<code>/var/log/auth.log</code>	<code># Authentication and authorization logs</code>
<code>/var/log/syslog</code>	<code># General system activity logs</code>
<code>/var/log/kern.log</code>	<code># Kernel messages</code>
<code>/var/log/messages</code>	<code># General system messages (non-systemd)</code>

How Logging Works on Linux

4 - Accessing Logs

- + Use `cat`, `less`, or `tail` to view log files
- + Use `grep` or `awk` to search and filter
- + Use `journalctl` on `systemd` systems to query the system journal

```
# View recent logs with details
journalctl -xe

tail -f /var/log/auth.log
```



Types of Linux Log Files

Types of Linux Log Files

1 - Authentication Logs

- + Location(s):
 - + `/var/log/auth.log`
 - + `/var/log/secure`
- + Contains login attempts, SSH access, sudo usage.
- + Useful for detecting brute force attacks, privilege escalation, unauthorized logins.

Types of Linux Log Files

2 - System Logs

- + Location(s):
 - + `/var/log/syslog`
 - + `/var/log/messages`
- + Includes general system and daemon activity.
- + Useful for spotting service crashes, system errors, reboots.

3 - Kernel Logs

- + Location: `/var/log/kern.log`
- + Captures messages from the Linux kernel (e.g., hardware errors, driver issues)

Types of Linux Log Files

4 - Application Logs

- + Location(s): Varies by application, often in `/var/log/` or custom paths. For Example:
 - + `/var/log/apache2/access.log`
 - + `/var/log/mysql/error.log`
- + Custom/3rd Party applications may write to their own log.

Types of Linux Log Files

5 - Audit Logs

- + Tool: `auditd` (Linux Audit Daemon)
- + Location: `/var/log/audit/audit.log`
- + Tracks system calls, file accesses, user activity at a granular level.
- + Used for regulatory compliance and detailed forensics.

6 - Systemd Journal (if applicable)

- + Tool: `journald`
- + Command: `journalctl`
- + Captures kernel logs, service logs, authentication events, and more in a centralized binary journal



Use Cases For SOC Analysts

Use Cases For SOC Analysts

Use Case	Relevant Logs
Brute-force detection	<code>/var/log/auth.log</code>
Malware behavior	<code>/var/log/syslog</code> , <code>/var/log/messages</code> , <code>journalctl</code>
Root access tracking	<code>/var/log/auth.log</code> , <code>audit.log</code>
Lateral movement	SSH logs in <code>/var/log/auth.log</code>
Data exfiltration scripts	Custom script logs, process auditing

Why It Matters

- + *Linux logs provide deep visibility into system behavior and user actions*
- + *Critical for forensics, audit trails, and detection of compromise*
- + *Lightweight and customizable, logs can be centralized for SIEM integration*



Linux Log Files: Quick Reference

Linux Logs: Quick Reference

Log File	Location	Purpose
System Logs	<code>/var/log/syslog</code>	General system messages (Ubuntu/Debian)
General System Messages	<code>/var/log/messages</code>	System-wide logs (RHEL/CentOS)
Authentication Logs	<code>/var/log/auth.log</code>	SSH, sudo, and login activity
Secure Log (alt)	<code>/var/log/secure</code>	Auth & access logs on RHEL/CentOS
Kernel Logs	<code>/var/log/kern.log</code>	Messages from the Linux kernel
Audit Logs	<code>/var/log/audit/audit.log</code>	Detailed system call-level security events
Boot Logs	<code>/var/log/boot.log</code>	Boot-time system logs
Cron Logs	<code>/var/log/cron</code>	Scheduled task execution logs
Dmesg (Ring Buffer)	<code>dmesg</code>	Kernel messages from current boot
Application Logs	<code>/var/log/<app>/</code>	Varies (e.g., Apache: <code>/var/log/apache2/</code>)



Essential Linux Log Commands

Essential Linux Log Commands

+ View Logs

```
less /var/log/syslog  
less /var/log/auth.log
```

+ Real-Time Monitoring

```
tail -f /var/log/syslog  
journalctl -f
```

Essential Linux Log Commands

+ Search Logs

```
grep "Failed password" /var/log/auth.log  
journalctl | grep sshd
```

+ Filter by Time (journalctl)

```
journalctl --since "1 hour ago"  
journalctl --since "2024-05-01" --until "2024-05-15"
```

Essential Linux Log Commands

+ View Kernel Messages

```
dmesg | less
```

Thank You!

Logging Lifecycle

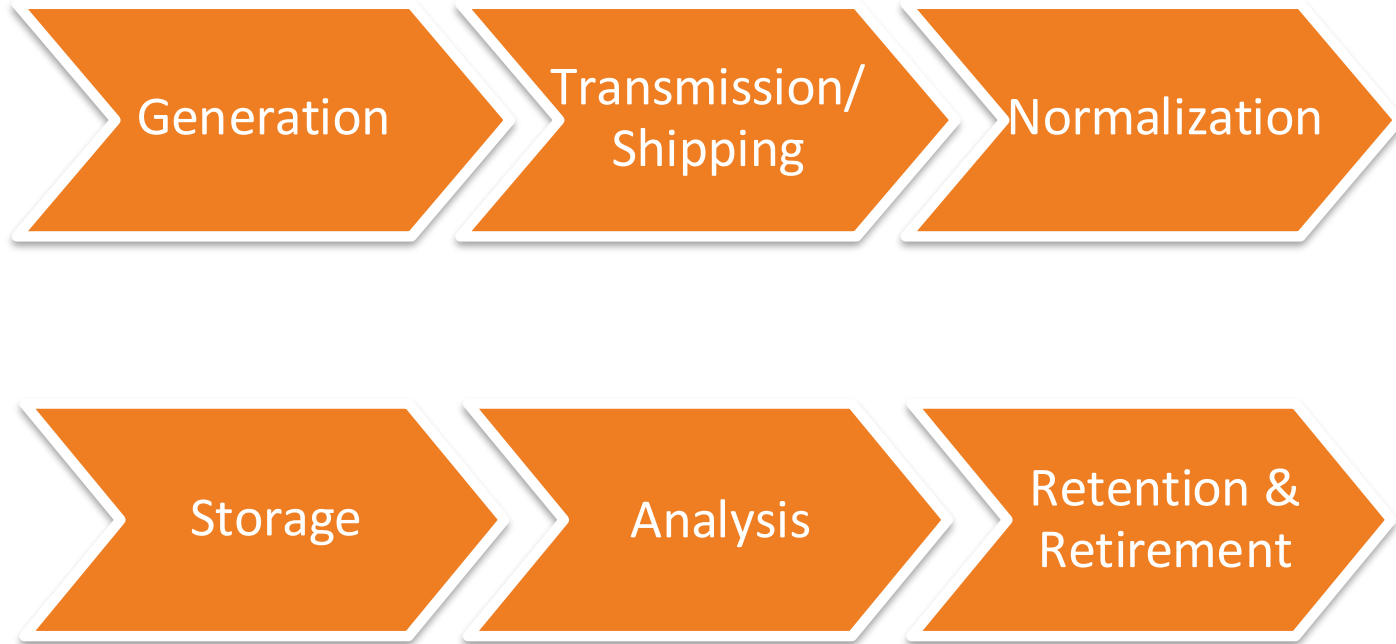


Logging Lifecycle

Why is This Important?

- Knowing what logs are available, what information can be found in them helps speed up initial analysis.
- In order to be an effective SOC analyst, you require a deeper understanding of the logs themselves:
 - Where do they come from?
 - Where do they go?
 - Can assist with trusting the data
- Understanding the logging lifecycle also provides context during initial investigation
- Can identify potential gaps
 - T1 analysts can spot missing information quickly
- View the “whole picture”

Logging Lifecycle



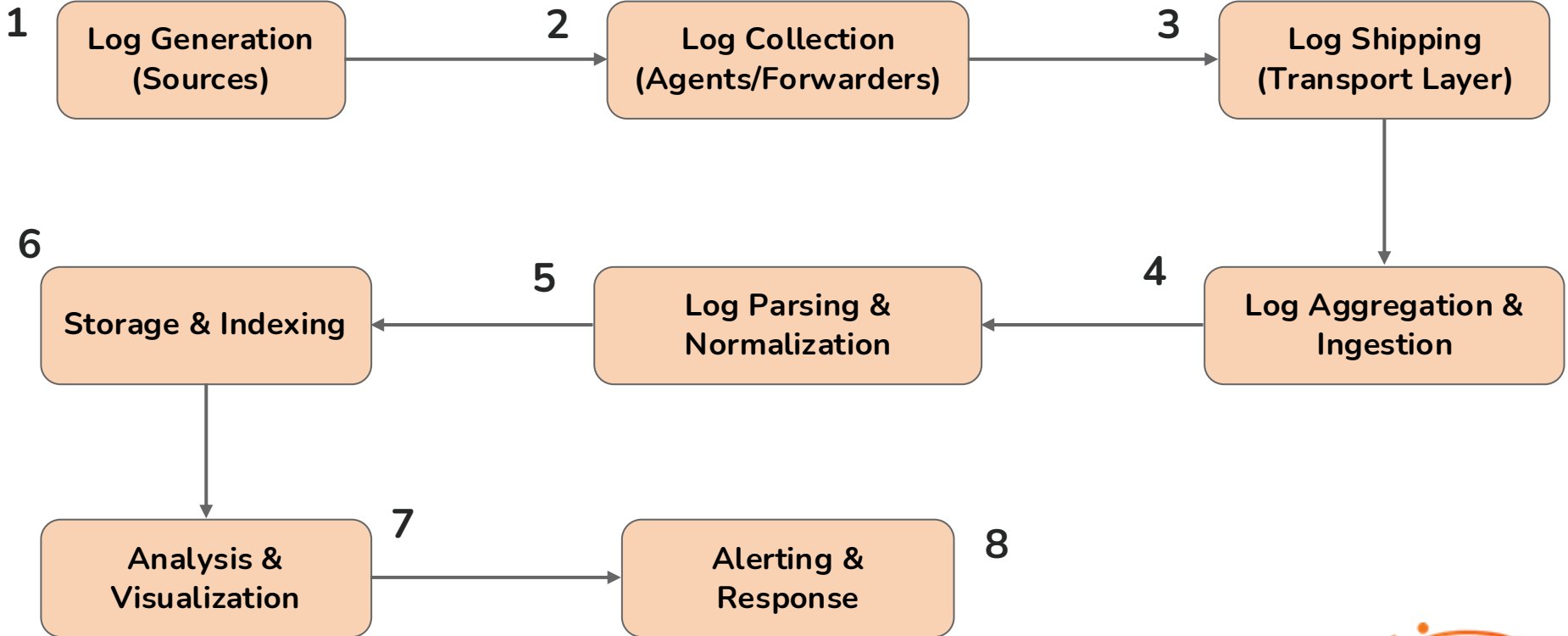
Centralized Logging

A **centralized logging** pipeline is the architecture and process through which logs from diverse systems are **collected**, **transported**, **processed**, **stored**, and **analyzed** in a **central location**.

This central location is typically a SIEM (Splunk) or a log analytics platform (ELK Stack).

It is essential for incident detection, threat hunting, auditing, and forensic investigation.

Core Components of a Centralized Logging Pipeline



Thank You!

Log Collection

What is Log Collection?

Log collection is the process of gathering log data from various systems, services, and devices within an IT environment.

These logs are generated by:

- + Endpoints (e.g., Windows, Linux)
- + Network devices (e.g., firewalls, routers)
- + Applications (e.g., web servers, databases)
- + Security tools (e.g., antivirus, IDS/IPS)

The primary goal of log collection is to centralize visibility, support monitoring, and prepare for analysis or alerting.



How Log Collection Works

Log collection is the first step in a centralized logging pipeline, crucial for monitoring, detection, alerting and forensic investigation.

- + Logs are either pulled (queried on demand) or pushed (sent automatically).
- + Collection can be agent-based (e.g., Filebeat, Winlogbeat) or agentless (e.g., syslog).
- + Logs may be collected in raw format or parsed/normalized during ingestion.

Push Based Collection

- + In a push model, the source system (e.g., a Linux server) actively sends (pushes) its logs to a central destination such as a log server or SIEM.
- + How it works:
 - + A log shipper/agent on the endpoint forwards logs.
 - + Sent over TCP/UDP, Beats, or HTTP protocols.
 - + The receiving system is passive, waiting for incoming logs.
- + Examples:
 - + rsyslog on Linux pushing logs to a remote server.
 - + Winlogbeat pushing Windows Event Logs to ELK.
 - + A firewall pushing logs via syslog to a SIEM.

Push Based Collection

+ Benefits:

- + Near real-time delivery
- + Minimal configuration on the central system

+ Challenges:

- + Source must be trusted to ship logs
- + Delivery can fail silently if network issues occur

Pull Based Collection

- + In a pull model, the central system (e.g., SIEM or collector) requests (pulls) logs from endpoints on a schedule or trigger.
- + How it works:
 - + Collector authenticates with the source system
 - + Uses SSH, WMI, API, or shared folders to retrieve logs
 - + Suitable for systems that can't run agents
- + Examples:
 - + A SIEM pulling logs via WMI from Windows machines
 - + Pulling Apache logs from a web server over SSH/SCP
 - + Using SNMP or APIs to collect logs from devices

Pull Based Collection

+ Benefits:

- + Centralized control of collection
- + Useful for legacy systems or those where agents are impractical

+ Challenges:

- + Higher network load
- + Pull intervals can create latency
- + Requires secure and reliable access to source systems

Agent-Based Collection

- + In this model, a lightweight agent is installed on the host system. It monitors logs in real-time and sends them to a log processor or SIEM.
- + How it works:
 - + Agent reads log files or system APIs
 - + Formats and forwards logs (e.g., JSON)
 - + Can add metadata or tags before shipping
- + Examples:
 - + Filebeat for Linux log files
 - + Winlogbeat for Windows Event Logs
 - + NXLog or Sysmon for advanced Windows telemetry

Agent-Based Collection

+ Benefits:

- + Efficient and real-time
- + Resilient (local buffering, retry mechanisms)
- + Can enrich or filter logs before shipping

+ Challenges:

- + Requires installation and maintenance on every endpoint
- + May raise concerns in tightly controlled environments

Agentless Collection

- + Agentless methods don't require installing anything on the source. Instead, they rely on native protocols and open ports to collect logs.
- + How it works:
 - + Uses WMI, SSH, syslog, or API polling
 - + Typically involves periodic access from a collector
- + Examples:
 - + Collecting logs from Windows using WMI
 - + Gathering logs from network devices via syslog
 - + Querying audit logs from a web app via REST API

Agentless Collection

+ Benefits:

- + No agent deployment overhead
- + Easier in environments with strict software policies

+ Challenges:

- + Less reliable or slower (compared to agent-based)
- + May miss transient logs due to polling delay
- + Complex to secure and scale

Thank You!

Log Shipping

What is Log Shipping?

Log shipping is the process of *transferring collected logs* from the source system to a **centralized log analysis platform or SIEM** (Security Information and Event Management) system such as ELK, Splunk.

Importance of Log shipping:

- + *Enables centralized analysis and correlation.*
- + *Prevents logs from being tampered with on compromised systems.*
- + *Supports real-time alerting and automated detection.*
- + *Ensures long-term storage and compliance.*

Log Collection vs. Log Shipping

Aspect	Log Collection	Log Shipping
Purpose	Gather logs from local/system sources	Send logs to centralized platform
Examples	Auditd, journald, Event Viewer	Filebeat, Winlogbeat, rsyslog, syslog-ng
Destination	Local store or temporary buffer	Logstash, Elasticsearch, Splunk, SIEM
Transport Layer	N/A (local process)	Syslog, Beats, Kafka, HTTP API, TCP/UDP

Common Log Shipping Tools

Tool	OS	Use Case
Filebeat	Linux	Ship flat log files (e.g., <code>/var/log/</code>)
Winlogbeat	Windows	Ship Windows Event Logs
rsyslog/syslog-ng	Linux	Ship logs using syslog format
Logstash	Cross-platform	Parse, enrich, forward logs
NXLog	Windows	Alternative to Winlogbeat, custom logs
Fluentd	Cross-platform	Flexible, plugin-based shipping

Security Best Practices

- + Use TLS encryption to secure logs in transit.
- + Buffer logs locally to avoid data loss during downtime.
- + Enable authentication and signature verification if supported.
- + Separate log collection infrastructure from production systems.

Thank You!

Log Aggregation

Log Aggregation

Log aggregation is the process of collecting and combining log data from multiple sources into a single, centralized system for easier search, correlation, analysis, and monitoring.

It acts as the consolidation phase in the log pipeline and is essential for building situational awareness and enabling effective incident detection and response.

Log Aggregation

Modern environments generate logs from a wide range of systems. These logs are often scattered, use different formats, and are stored in different locations.

Log aggregation solves this by unifying logs, allowing responders to:

- + View and analyze all logs from one place
- + Perform correlation across systems (e.g., login from X followed by alert on Y)
- + Detect patterns and anomalies across hosts/networks
- + Accelerate investigations and reduce detection time



Importance of Log Collection, Shipping & Aggregation

Importance of Log Collection, Shipping & Aggregation

Component	Definition	Why it matters in the SOC
Log Collection	Gathering logs from endpoints, servers, apps, and devices	Ensures all relevant security events are captured for monitoring and analysis.
Log Shipping	Transmitting logs from source to central location (SIEM, ELK)	Enables reliable, timely delivery of logs for detection and investigation.
Log Aggregation	Centralizing logs from multiple sources for unified analysis	Supports correlation, visibility, and timeline reconstruction across the environment.



Key Terminology

Key Terminology

Term	Definition	Relevance
Log Source	The origin system or application that generates logs (e.g., Windows host, firewall, web server).	Knowing the log source helps responders trace the activity's origin and determine coverage.
Log Collector / Agent	A software component installed on a host that gathers log data (e.g., Filebeat, Winlogbeat).	Ensures log capture at the host level; critical for EDR visibility.
Log Aggregator	A system that receives and consolidates logs from multiple sources (e.g., Logstash, Fluentd).	Centralizes data for easier analysis and correlation.
Log Shipper	Component or agent that forwards collected logs to a centralized platform or SIEM.	Enables secure and reliable delivery of logs for detection and analysis.
Syslog	A widely used protocol for sending log messages, typically over UDP/TCP.	Common in network device logs and often used for infrastructure-level visibility.
Beats Protocol	A lightweight protocol used by Elastic Beats (e.g., Filebeat, Winlogbeat) to send logs.	Preferred for structured, reliable log transmission in ELK-based environments.

Key Terminology

Term	Definition	Relevance
Log Format	The structure in which a log message is recorded (e.g., JSON, Syslog, CEF).	Affects how easily logs can be parsed, indexed, and correlated.
Log Ingestion	The process of receiving and parsing logs into a storage or analysis system.	Crucial for ensuring that logs are stored, searchable, and usable.
Log Normalization	Converting different log formats into a standard structure (fields, labels).	Enables cross-source correlation and detection.
Log Parsing	Extracting structured fields from raw log data (e.g., timestamp, user, action).	Needed to create detection rules, dashboards, and alerts.
Log Retention	The policy for how long logs are stored before being archived or deleted.	Impacts historical investigations, compliance, and forensics.
Buffering	Temporary local storage of logs during network interruptions or load.	Prevents data loss during outages or SIEM downtime.

Key Terminology

Term	Definition	Relevance
Forwarder	Another term for a shipper or lightweight agent that sends logs (e.g., Splunk Universal Forwarder).	Ensures continuous log flow to central analysis tools.
Indexing	The process of organizing and storing logs in a searchable structure (e.g., Elasticsearch index).	Makes it possible to query and correlate logs quickly.
Time Synchronization	Ensuring all systems use the same time (via NTP).	Essential for timeline reconstruction and correlation across systems.
Log Enrichment	Adding context to logs (e.g., geolocation, hostname, user details).	Improves incident triage, detection accuracy, and investigation speed.

Thank You!

Log Collection & Centralization



Centralized Logging

- Single destination for all logs in network
- Typically, one dashboard to view all logs and analysis
- Capabilities & benefits
 - One place to go for all logs
 - Ability to introduce automation and alerting
 - Including automatic countermeasure steps
 - Analysis of all correlated logs
 - Manual or automated
- Increases difficulty for attackers altering/deleting logs
 - Attackers frequently delete logs to cover tracks
 - Offloaded logs are protected*

Collection Methods

- Push and pull
- Agents vs agentless
- Real-time collection for more critical systems
 - Allows for timely alerts and automation
- Lower-tier systems can use scheduled log shipments
 - Data may be used for IR, but not critical for alerting and immediate response
- Time synchronization
 - Critical importance to ensure effective analysis

Push vs Pull

- Push
 - System sends logs to central server
 - syslog, FTP, HTTP API, vendor-specific, etc
 - Can be real-time as logs are generated, or scheduled
 - Usually used for most critical data
- Pull
 - Log server connects to source and downloads logs
 - Usually performed in batches on a schedule
- For most critical logs - push
 - File system access (protect against data exfil and ransomware)
 - Authentication (alert on brute force, password spraying, etc)

Agent vs Agentless

Agent	Agentless
Software package installed on source	Usually uses pull methods
Log shipment typically real time, pushed	May use native push (FTP, syslog, etc)
Used for fastest log collection	Speed depends on source, method
Availability depends on logging system	

Aggregation and Correlation

- Aggregation - collecting all logs in one place
- Correlation - comparing logs and establishing connections and common information

- Starts with log normalization
- SIEM (or other system) analyzes all collected data
- All log data stored on one system, allows logs to be analyzed against other logs
- Results in better intelligence than standalone log information

Log Collection & Aggregation With Splunk

Lab Overview

In this lab, you'll configure **two servers** to **send log data to a Splunk instance** that resides on SERVER01.

DC01 will need specified Windows event logs, including some AD information sent, and LINUX01 will need specific auth log files sent.

What you'll do in this lab:

- + Collect logs from DC01 (Windows AD) and LINUX01 (Linux auth logs).
- + Ship logs to a centralized Splunk instance (SERVER01).
- + Analyze logs for visibility and incident response.

Lab Overview

You have been tasked with collecting log information from two servers in the organization.

Your director has asked for security event logs and basic AD information to be collected from DC01 and sent to the Splunk server on SERVER01.

In addition, you have been asked to have authorization logs from the Linux server indexed into Splunk as well.

Lab Objectives

- + Collect Security Event Logs and Active Directory logs from DC01.
- + Collect authorization logs (/var/log/auth.log) from LINUX01.
- + Configure all logs to be shipped to and indexed by Splunk on SERVER01.
- + Ensure reliable and secure delivery over port 9997.

Lab Topology

**Windows AD
Domain
Controller**

IP: 172.31.115.100



DC01

Linux Server

IP: 172.31.115.111



LINUX01

In this lab, the log collection is push-based.

The Splunk Universal Forwarder installed on DC01 (Windows AD server) and LINUX01 (Linux server) is actively sending (pushing) logs to the central Splunk instance (SERVER01) over port 9997.



SERVER01

Splunk

IP: 172.31.115.110

Port: 9997

Lab Demo: Log Collection & Aggregation With Splunk

Thank You!

Basic Log Interpretation & Analysis



Basic Log Interpretation & Analysis

What is Analysis?

- Examining collected data to draw conclusions and build actionable intel
 - Manual & automated
- Take all correlated data from multiple systems
- Cross-check logs against other logs and systems
- Based on data found, put together timeline of what occurred
 - Build actionable intelligence
 - Draw conclusions from gathered intelligence
 - What happened? When? From/to where?
 - What are the impacts?
 - Create IOCs - Indicators of compromise
- Goal is to build a full picture that tells the story

Build a Story

- Logs tell a story of what happened
 - Provide evidence
- Analysts put the story together
 - Timeline
 - Events
 - Who
- Most of “storytelling” happens at T2+
- T1 analysts start the process
 - Determine if there is a story to tell

What's In a Log?

- Timestamp

Sep 23 14:13:54

1676461685.434098

- Event ID or code

Event ID:

4624

- Source/destination

- User or account

- Process

systemd[1]: Started Session 9522 of User brian.

- Action

- Message

```
Start-Date: 2025-09-19 06:46:52
Commandline: /usr/bin/unattended-upgrade
Upgrade: libopenjp2-7:amd64 (2.4.0-6ubuntu0.3, 2.4.0-6ubuntu0.4)
End-Date: 2025-09-19 06:46:52
```

Initial Analysis

Normal or Suspicious?	Understand the Context	True positive vs False positive	Pivot & Watch for Patterns	Remember Timestamps
Filter out the noise to get to the signals	What else is happening in the logs?	True positive - alert/log identified as malicious, and really is	Some patterns are easier to spot than others	Build a sequence of events (story)
Requires understanding of what “normal” is in environment	Any trends or high profile attacks to be aware of?	False positive - identified as malicious, but is not	Pivoting - start with one suspicious event, check related logs for additional context	Firewall event -> login attempts -> login success -> process execution
Spot anomalies without over-analyzing				Can help distinguish isolated event from larger incident

Actionable Intelligence

- Informative data gathered from log analysis that guides next steps
- Used to create mitigation strategies and build countermeasures
- Built from in-depth analysis of multiple logs
 - Correlated data
 - Tells full story of event or incident
- **Actionable**
 - Not just raw information, but information that leads to specific actions

Thank You!

Log Analysis Tools



Log Analysis Tools

Why Tools?

- As we've already seen - tools make logs easier to use and process
- Logs = high volume, lower direct usability
- Tools make logs easier
 - Collect logs in one location
 - Allow for easy searching
 - Provide dashboards, alerts, automations
 - AI summarization
- SOC analysts rely on their tools
 - Tools used daily
 - Raw logs are not

Tool Types

- SIEM platforms
 - Paid - Splunk, LogRhythm, Sentinel, QRadar, etc
 - Free/open source - ELK/Elastic Stack, Wazuh, Security Onion
- Cloud logging
 - Proprietary to specific platform (mostly)
 - AWS CloudWatch, Azure Monitor, etc
- Analysis tools
 - Typically used on raw logs
 - Wireshark
 - PowerShell, Python (other scripting languages)
 - grep

Supplementing Log Data

- Tools enrich logs automatically
 - Add threat intelligence
 - Internal asset information
 - Geolocation data
- Sometimes more info is needed
 - SIEM may not provide (or have access to)
 - OSINT (Open Source Intelligence)
 - Paid threat intelligence feeds/sources
 - Internal resources
- Always include additional information in tickets

Analyst's Role with Tools

- Level 1 SOC Analyst
 - Basic searching in SIEM
 - Sometimes using pre-defined queries
 - Results filtering
 - Pre-configured dashboards
 - Documentation
- Level 2+ Analysts/IR/Hunters
 - Packet analysis with Wireshark
 - Writing correlation and detection rules
 - Using scripting languages for detection & hunting
 - Memory forensics tools

Thank You!

SIEM

Introduction



Introduction To SIEM

What is a SIEM?

A **SIEM** (*Security Information and Event Management*) is a **centralized platform/solution** that provides **real-time visibility, correlation, detection, and alerting** based on log and event data collected across an organization's infrastructure.

As the name suggests, a SIEM combines two core capabilities:

1. **Security Information Management (SIM)** – Historical data analysis and log management.
2. **Security Event Management (SEM)** – Real-time monitoring and alerting.

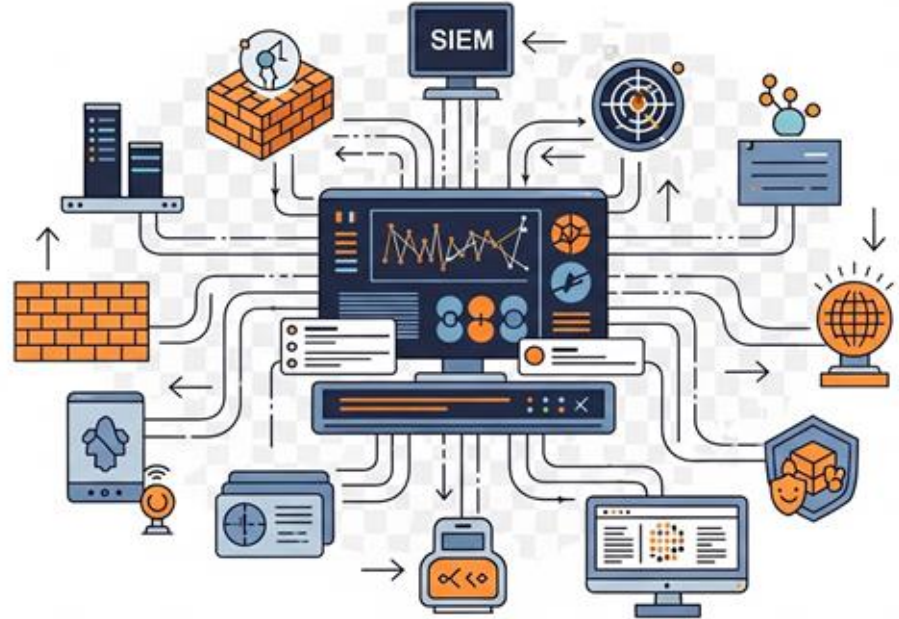
SIEM = SIM + SEM



What is a SIEM?

SIEM solutions are able to:

- + Analyze current or historical events and log data, perform event correlation and threat monitoring (**Security Event Management**)
- + Retrieve and index log data from disparate sources for analysis and reports (**Security Information Management**)



SIEM

- Security Information & Event Management
 - Splunk, ELK, Security Onion, LogRhythm, etc
- Used for log/data analysis
- Collects logs from multiple sources
 - Aggregation, correlation, normalization, and enrichment
- Capable of real-time analysis and alerting
- They provide dashboards & visualizations
- Allows for raw log searches
- Primary tool for L1 SOC Analysts

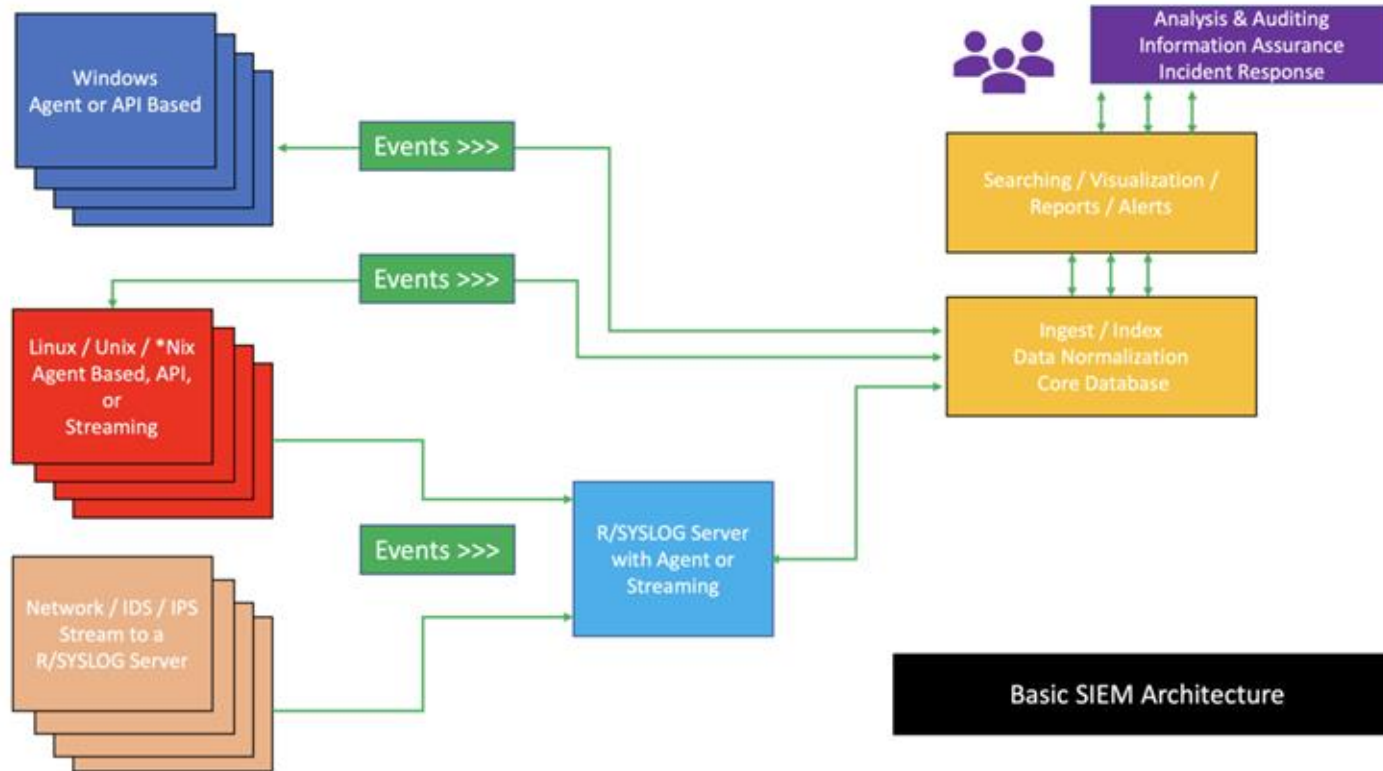
Popular SIEM Solutions

SIEM Solution	Open Source	Description
Splunk Enterprise Security	No	A leading commercial SIEM platform offering scalable log management, real-time monitoring, and powerful analytics capabilities. Widely used in enterprise environments.
IBM Security QRadar	No	IBM's flagship SIEM providing comprehensive threat detection, log correlation, and automated response. Integrates well with other IBM products.
LogRhythm NextGen SIEM	No	Combines log management, UEBA, and SOAR capabilities. Known for fast detection and response capabilities and strong compliance features.
Microsoft Sentinel	No	A cloud-native SIEM built on Azure. Offers AI-driven analytics, scalable data ingestion, and seamless Microsoft ecosystem integration.
Elastic Security (ELK Stack)	Yes	Built on Elasticsearch, Logstash, and Kibana (ELK), this SIEM offers open-source core components. Some advanced features require a commercial license under Elastic's dual licensing model.
Wazuh	Yes	A fully open-source security platform with log analysis, file integrity monitoring, intrusion detection, and compliance reporting. Highly extensible and community-driven.

Popular SIEM Solutions

SIEM Solution	Open Source	Description
OSSIM (Open Source SIEM)	Yes	Maintained by AT&T Cybersecurity, OSSIM integrates several open-source tools for event correlation and threat detection. A cost-effective, entry-level SIEM.
Security Onion	Yes	A free and open-source Linux distro combining Zeek, Suricata, Snort, Wazuh, and the ELK Stack for enterprise security monitoring and log management.
Graylog	Yes	An open-source log management solution with real-time search and alerting. It can be extended to function as a SIEM with additional features and plugins.
OpenSearch	Yes	A community-driven fork of Elasticsearch and Kibana. Offers open-source search, analytics, and visualization tools—often used as a foundation for custom-built SIEM solutions.

SIEM Architecture



How a SIEM Works

A SIEM follows a log pipeline process with these core stages:

1. Log Collection

- + Gathers logs and events from across the environment:
 - + Windows/Linux servers
 - + Firewalls, IDS/IPS
 - + Applications, endpoints, authentication systems
 - + Cloud and on-prem infrastructure

2. Normalization & Parsing

- + Converts raw logs into a standardized format
 - + Extracts fields like IP addresses, usernames, timestamps



How a SIEM Works

3. Aggregation & Storage

- + Stores logs in indexed databases.
- + Allows for fast searching, reporting, and auditing.

4. Correlation & Detection

- + Analyzes patterns across multiple systems
- + Matches activity against detection rules (e.g., **brute force + suspicious login = alert**)

How a SIEM Works

5. Alerting & Dashboards

- + Raises alerts when suspicious activity is detected.
- + Presents visual dashboards for SOC analysts to monitor.

6. Search & Investigation

- + Enables deep-dive investigation and analysis.
- + Supports threat hunting and timeline reconstruction.

What Is a SIEM Used For?

Use Case	Description
Detection	Identifies threats in real-time (e.g., malware, privilege abuse, C2 activity)
Log Analysis	Centralized analysis of logs from disparate systems
Alerting	Notifies analysts of high-risk events or rule matches
Threat Hunting	Enables proactive searches for indicators of compromise (IOCs)
Compliance & Auditing	Stores logs and proves security control effectiveness (e.g., PCI-DSS, HIPAA)
Forensic Investigations	Reconstructs events post-incident

Why SIEMs Are Critical for SOC Analysts

A SIEM is often the primary tool used by incident responders and SOC analysts. It provides:

Centralized Visibility

- + All logs in one place.
- + Cross-system correlations (e.g., login + file access + external connection).

Fast Detection

- + Real-time alerts reduce time to detect (MTTD).
- + Triage queues help prioritize incidents.



Why SIEMs Are Critical for SOC Analysts

Contextual Awareness

- + Enriched alerts include context: user, system, location, threat type.
- + Helps analysts and responders understand the scope and impact of an attack.

Investigation, Escalation & Response

- + Timeline views, raw logs, and pivoting across data.
- + **Helps answer the question(s):**
 - + **What happened?**
 - + **Who was affected?**
 - + **What's the root cause?**

Detection Examples

- Possible brute force attacks
- Excessive file copying
 - Indication of possible data exfil
- DDoS attack
 - Multiple simultaneous attacks from different sources
- File integrity compromise
 - Unauthorized or unexpected changes made to certain files

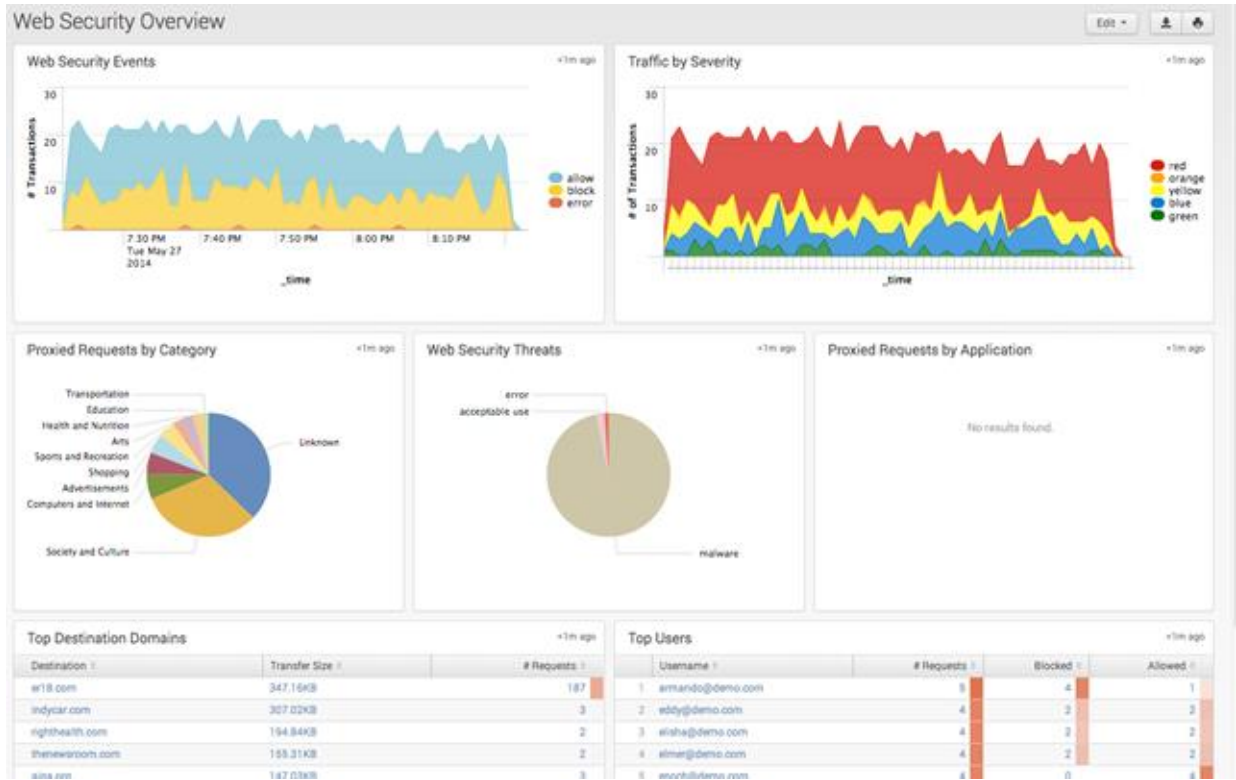
SIEM Automation

- Different types/vendors provide different levels of automation
- ML/AI techniques can be used to enhance capabilities
- Monitoring rules can be configured to automatically trigger alerts
- Those alerts can also trigger actions
- Example:
 - Multiple failed logins on multiple accounts from one source IP
 - Alert generated to SOC
 - Automation blocks source IP in firewall to stop attack attempt

Limitations

- Not all logs may be available
 - Leads to potential gaps in visibility
 - May require additional configuration, or might indicate problem
- False positives
- Depending on available data, searches may be time consuming
 - Complex searches require more time
 - Large datasets require more time to query
- Knowing when to escalate based on missing data is important

Splunk Example Dashboard



Thank You!

Dashboards & Visualizations



Dashboards & Visualizations

Dashboards

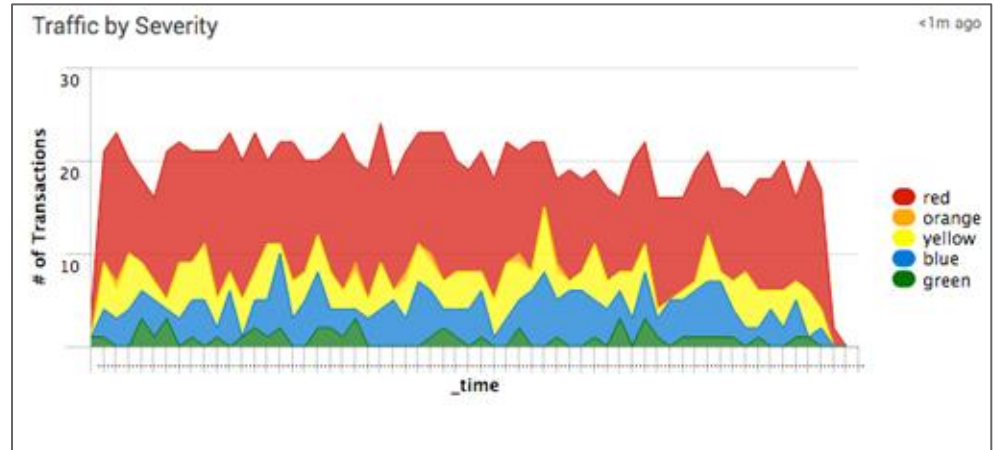
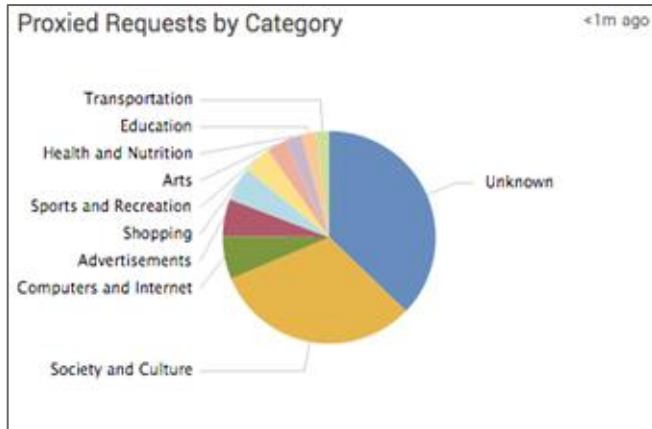
- Visual dashboards provide a high-level overview of the security posture.
- Enable at-a-glance visibility into alert volumes, trends, and source distribution.
- Highly customizable based on:
 - Source and type of ingested data
 - Desired metrics, KPIs, and operational context
- Can reveal potential issues or abnormal patterns without triggering alerts.
- Help reduce alert fatigue by supporting contextual awareness and prioritization.
- Effective only when dashboards are actively monitored and reviewed.
- Complement, but do not replace automation, correlation, and alerting mechanisms.

Dashboard Elements

- Charts and graphs - Used to visualize trends over time.
- Tables and lists - Show top items, like top IPs connecting to a system, top users with failed logins, system or network with highest number of alerts, etc.
- Heatmaps or geolocation maps - Highlight where connections are coming from. Can show potential foreign attack origins.
- Various widgets - Almost endless list of customizable options (depending on SIEM in use).

Dashboard Elements

Charts & graphs



Tables & Lists

Top Users <1m ago

	Username	# Requests	Blocked	Allowed
1	armando@demo.com	5	4	1
2	eddy@demo.com	4	2	2
3	elisha@demo.com	4	2	2
4	elmer@demo.com	4	2	2
5	enoch@demo.com	4	0	4

Intentional Dashboards

- Intentional → dashboards built with specific purposes in mind:
- Operational dashboard
 - Real-time system health and activity
- Security monitoring
 - Failed logins, blocked firewall connections, EDR detections
- Threat intelligence
 - New updates from intelligence feeds
 - Correlation with network activity (hits against known bad IPs/domains)
- Compliance
 - Log retention information
 - Baseline configuration verification

EDR Alert Dashboard

Symantec Alerts



Critical

338

Major

203

Minor

1,697

Symantec Blocked



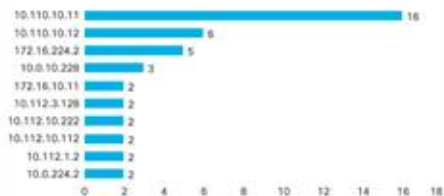
Firewall & Network Dashboard

Threats Summary

IP Address: Time: Traffic Direction: Blocked or not blocked:

Indications of Compromise by Host

Src Ip

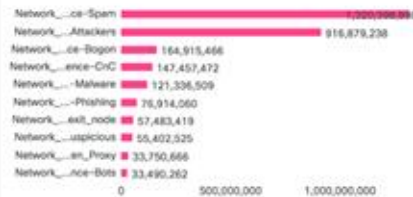


New Indications of Compromise Over Time



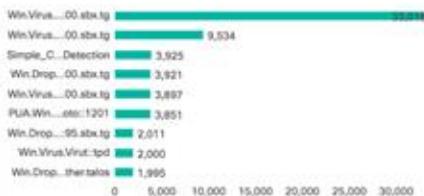
Connections by Security Intelligence Category

Security Intelligence Category



Malware Threats

Detection Name

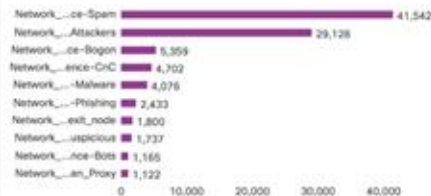


Intrusion Events by Impact Level



Top Security Intelligence Categories

Security Intelligence Category



Thank You!

Introduction To The ELK Stack



Elasticsearch



Logstash



Kibana



What is the Elastic Stack (ELK)?

The **ELK Stack** is a powerful, *open-source suite of tools* used for *searching, analyzing*, and *visualizing* large volumes of *data*, especially *log data*, in real time.

ELK is an abbreviation of the term "*Elastic Stack*", more specifically, it is an abbreviation of the names of the components that make up the stack:

- + **E** – Elasticsearch
- + **L** – Logstash
- + **K** – Kibana

What is the Elastic Stack (ELK)?

These **tools/components** are developed by **Elastic.co** and are **commonly used together** to process and analyze massive amounts of data efficiently.

The combination of these components is the reason it is referred to as a stack.

However, today the term **Elastic Stack** is more accurate, as it now includes additional tools like **Beats** and the **Elastic Agent**, which **enhance data collection and monitoring capabilities**.

Why was ELK Created?

In modern IT environments, systems generate huge volumes of logs from:

- + Web servers
- + Applications
- + Operating systems
- + Security tools (e.g., firewalls, antivirus)

Managing, searching, and making sense of this data manually is nearly impossible. ELK was created to:

- + Centralize log data from multiple systems.
- + Index and search through data quickly.
- + Visualize trends, patterns, and anomalies.
- + Enable real-time monitoring and alerting.

Core Purpose of the ELK Stack

The best way to understand what the ELK stack is used for is to ***think of ELK as a data pipeline***:

1. **Ingest** logs from various sources (via Logstash or Beats).
2. **Store** and **index** the data efficiently (in Elasticsearch).
3. **Explore** and **visualize** the data (using Kibana).

The flexibility and compatibility between the components that make up the stack makes ELK a go-to solution for:

- + Log management
- + Security monitoring
- + Application performance monitoring (APM)
- + Business intelligence
- + Operational analytics



Where/How is ELK Used?

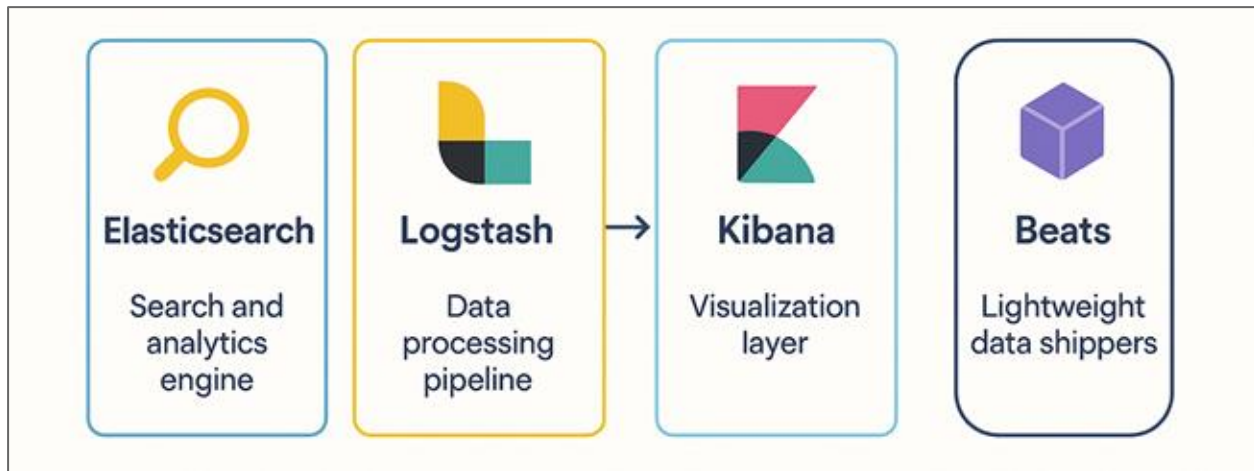
- + Enterprise IT departments for infrastructure monitoring.
- + DevOps teams for troubleshooting applications.
- + Security teams in Security Operations Centers (SOCs) for incident detection and response.
- + Cloud environments for centralized log management.

Core Components of the ELK Stack



Core Components of the ELK Stack

The **ELK Stack** is made up of **three core components**: Elasticsearch, Logstash, and Kibana. Furthermore, there are additional tools like Beats which are often integrated for enhanced log collection.



Core Components of the ELK Stack

Each component plays a specific role in the data processing pipeline. Let us take a closer look at each of them.

1 - Elasticsearch - The Search and Analytics Engine

Elasticsearch is a distributed, RESTful search and analytics engine designed for horizontal scalability and real-time performance.

Key Features:

- + Stores ***structured and unstructured data*** (logs, metrics, text, etc.).
- + Allows for ***near-instantaneous search and filtering***.
- + Built on Apache Lucene, offering powerful full-text search.
- + Highly scalable and fault-tolerant.

Use in Security Operations:

It's used to index and retrieve logs quickly, enabling security analysts to search for Indicators of Compromise (IoCs), track user activity, and pivot across datasets rapidly.



Core Components of the ELK Stack

2 - Logstash - The Data Processing Pipeline

Logstash is a **server-side data ingestion tool** that collects, transforms, and sends data to Elasticsearch.

Key Features:

- + Supports multiple input sources: syslog, files, APIs, etc.
- + Can parse, filter, and enrich log data using grok patterns or conditionals.
- + Output data to Elasticsearch, files, or even message queues like Kafka.

Use in Security Operations:

It helps normalize logs from different sources, extract important fields (like usernames, IPs, process names), and ensure clean, searchable data in Elasticsearch.

Core Components of the ELK Stack

3 - Kibana - The Visualization Layer

Kibana is the **frontend interface** that allows users to visualize data stored in Elasticsearch.

Key Features:

- + Create interactive dashboards and data visualizations (charts, graphs, tables).
- + Use KQL (Kibana Query Language) to filter and search data.
- + Supports real-time exploration of data.
- + Enables alerting, detection rules, and even timeline-based investigations in Elastic Security.

Use in Security Operations:

- Monitor real-time dashboards for suspicious activity.
- Visualize trends in log data (e.g., spike in failed logins).
- Drill down into specific events for investigation.

Core Components of the ELK Stack

4 - Beats (Add-on) - Lightweight Data Shippers

Beats are *lightweight agents* installed on endpoints to collect specific types of data and forward it to Logstash or Elasticsearch.

Popular/Common Beats:

- + **Filebeat:** Reads log files (e.g., Apache logs, system logs)
- + **Winlogbeat:** Collects Windows event logs
- + **Packetbeat:** Captures network traffic
- + **Metricbeat:** Gathers system metrics (CPU, RAM, etc.)

Use in Security Operations:

Beats are often used on endpoints and servers to ensure continuous and structured log forwarding from a wide range of sources.

ELK Stack in Security Operations

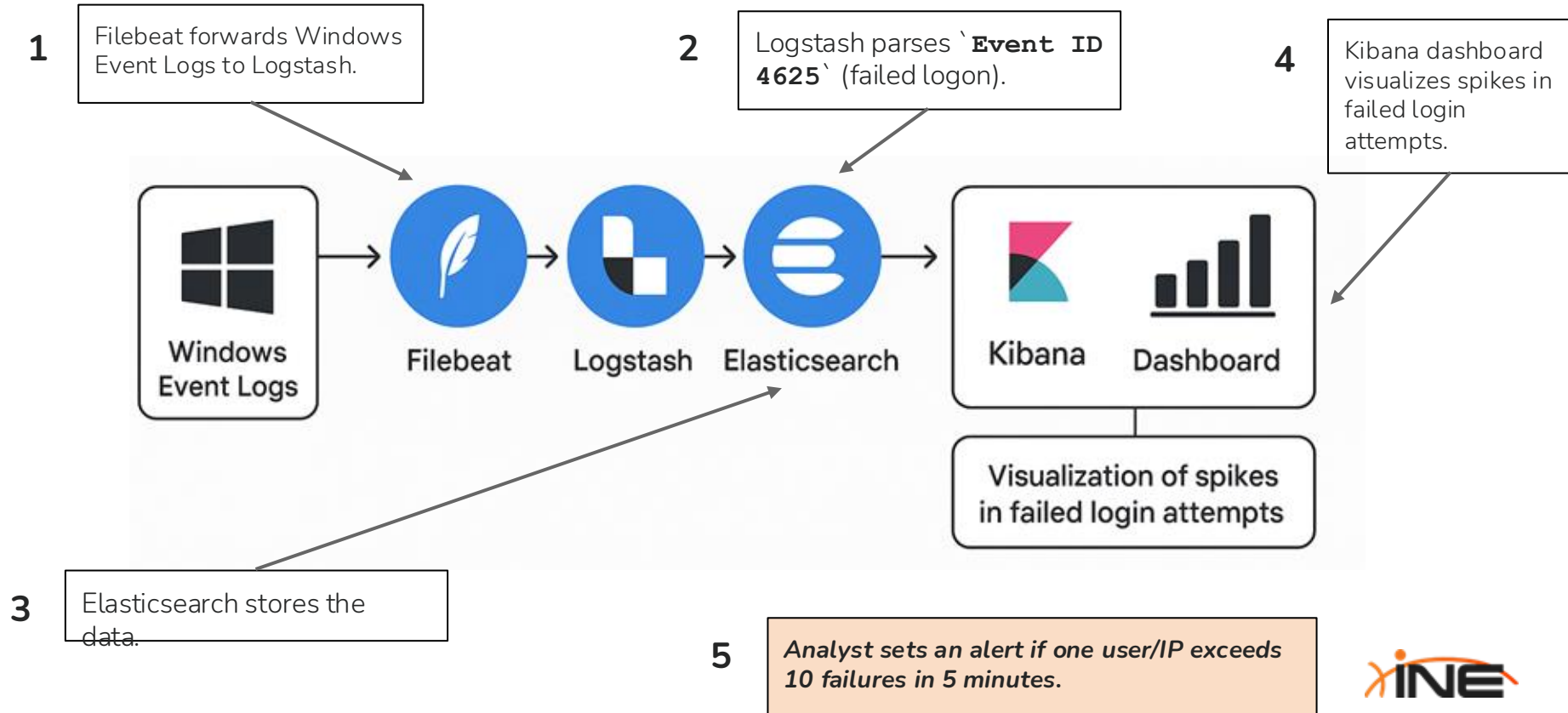


ELK Stack in Security Operations

The **ELK Stack** plays a central role in modern SOC's. Its ability to *ingest, store, analyze, and visualize log data* makes it indispensable for monitoring and responding to cyber threats.

Use Case	Explanation
Threat Detection	• ELK enables the detection of malicious behaviors by parsing and correlating logs across the environment. • Analysts can create detection rules (custom or using Elastic Security) to flag suspicious activities.
Incident Response	• When an alert is triggered, responders can pivot quickly to search logs in Elasticsearch via Kibana. • Allows for deep-dive investigations, tracing the origin, method, and impact of attacks.
Security Monitoring	• Real-time dashboards track critical security metrics like failed logins, abnormal outbound traffic, or changes in file integrity. • Alert thresholds can be set to escalate high-risk events automatically.
Threat Hunting	• Analysts use Kibana's search and filter capabilities to proactively look for anomalies or Indicators of Compromise (IoCs). • Custom queries help identify patterns that don't match known signatures.

Example: Detecting Brute Force Login Attempts



References



References & Further Reading

- + Elastic Official Documentation: <https://www.elastic.co/guide>
- + Elastic Security (SIEM on the ELK Stack):
<https://www.elastic.co/security>

Thank You!

Effectively Using ELK

Lab Scenario

The organization you work for is evaluating a customized ELK stack as a SIEM solution to enhance its intrusion detection capabilities.

The SOC manager tasked you with getting familiar with the ELK stack and its detection capabilities.

He also tasked you with translating common attacker behavior into ELK searches.

Lab Objective(s)

The learning objective of this lab, is to get familiar with the architecture and detection capabilities of the ELK Stack.

- + **Task 1: Add any fields you see fit to enhance your understanding of the data**
- + **Task 2: Create an actionable visualization**
- + **Task 3: Create a search to identify files that are named like system processes**
- + **Task 4: Create a search to identify suspicious services interacting with an executable from the Windows folder**
- + Task 5: Create a search to identify suspicious code injection
- + Task 6: Create a search to identify possible privilege escalation via weak service permissions
- + Task 7: Create a search to identify possible Windows session hijacking
- + **Task 8: Create a search to identify the whoami command being executed with System privileges**
- + Task 9: Create a search to identify LSASS loading a library not signed by Microsoft

Lab Demo: Effectively Using ELK

Thank You!

Alerting



Events, Alerts & Incidents

Understanding Events, Alerts & Incidents

In the context of security monitoring it is essential to distinguish between events, alerts, and incidents.

Misunderstanding these terms can lead to inefficient triage, wasted analyst time, or even missed breaches/intrusions.

Events

- + An **event** is any meaningful, **observable occurrence** detected from logs or telemetry.
- + It may be:
 - + A single log entry
 - + Multiple correlated log entries
 - + A normalized record created by a SIEM
 - + A structured representation of something that happened
- + Examples:
 - + A user logs into a workstation
 - + A file is opened or modified
 - + A process is created or terminated
 - + A packet is transmitted across a network

Events

- + Key Characteristics:
 - + Generated in large volumes (millions per day in large networks)
 - + Most are benign and part of normal operations
 - + Logged for auditing, troubleshooting, and monitoring

Think of events as raw data. They're the atoms of your security telemetry.

Alerts

- + An **alert** is a notification generated by a security monitoring system (e.g., SIEM, IDS, antivirus) ***when a predefined rule is triggered or condition is met***, often indicating potentially suspicious or malicious activity.
- + Examples:
 - + A login attempt from an unauthorized country
 - + A malware signature detected in memory
 - + A user added to the Domain Admins group unexpectedly
 - + An unusually large outbound data transfer

Alerts

- + Key Characteristics:
 - + Based on detection rules, heuristics, or behavioral baselines
 - + May include false positives
 - + Require triage and validation by analysts

An alert is a signal: “Hey, something might be wrong.”

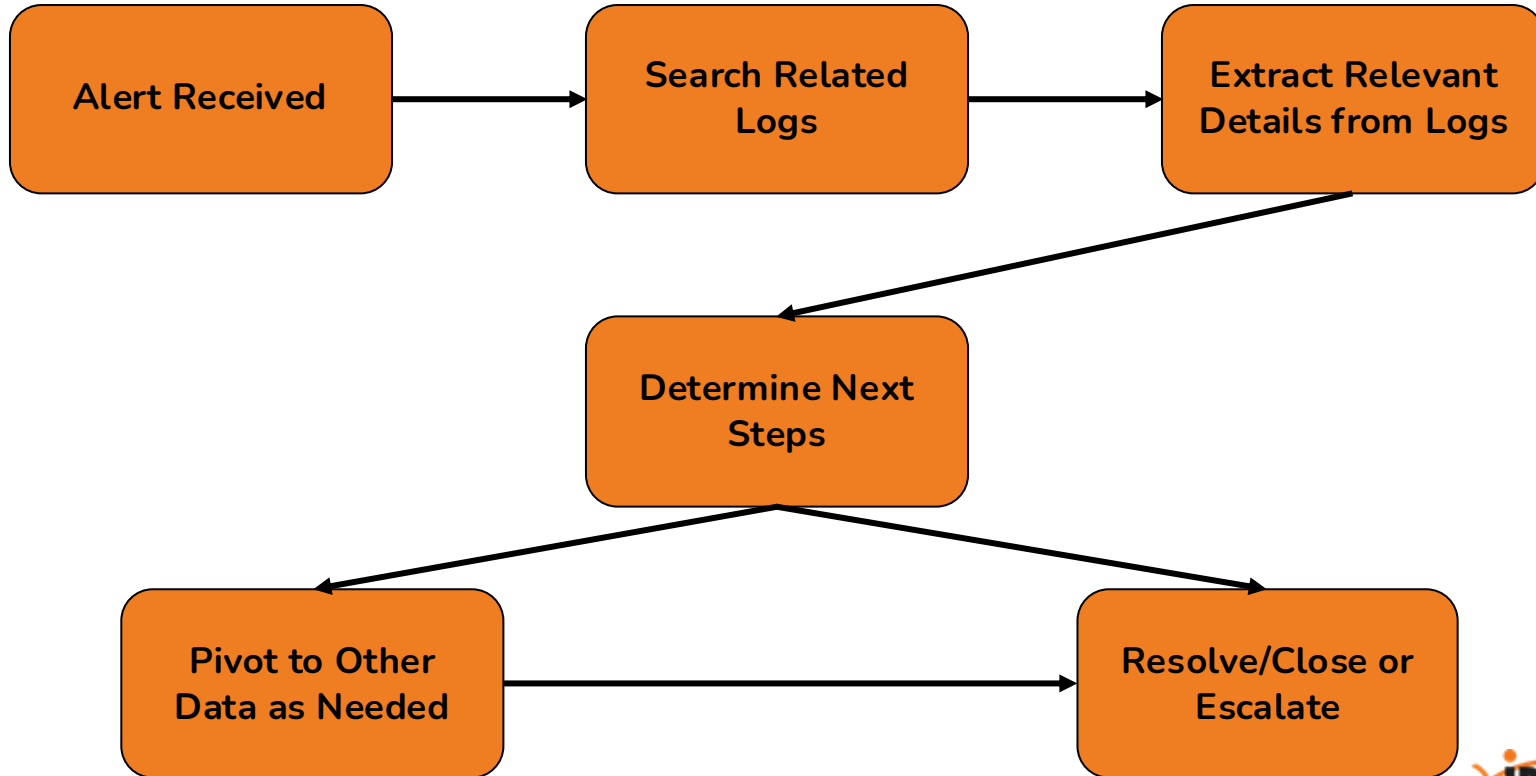
Alerts

- Analysts can't do everything manually
 - Can't watch all the dashboards
 - Can't review millions of events & logs by hand
- Notification triggered when event matches detection rule
- Allow important information to be highlighted
- Information that leads to SOC action
 - Ticket & investigation

Alert Creation Criteria

- The SIEM looks at events and automatically analyzes them.
- Correlation rules examine multiple entries
 - Account authentication + time + IP
 - Failed authentications + successful authentication (on single account)
- Thresholds examined
 - > 50 denied connections
 - > 15 failed authentications on account in 5 minutes
- Signatures
 - Malware hashes, other patterns
- Behavioral analytics - Unusual login times, anomalous processes, etc.
 - More advanced type of criteria

Analyst Workflow with SIEM



Validating Alerts

- Use available logs/intelligence to ensure true positive (or false positive)
- Example:
 - Alert: Multiple failed logins detected
 - SIEM search shows:
 - 42 failed logins from 123.45.67.89
 - Account is privileged
 - IP address located in foreign country
 - IP address flagged in threat intelligence
 - Outcome: escalate as likely brute-force attack

Incidents

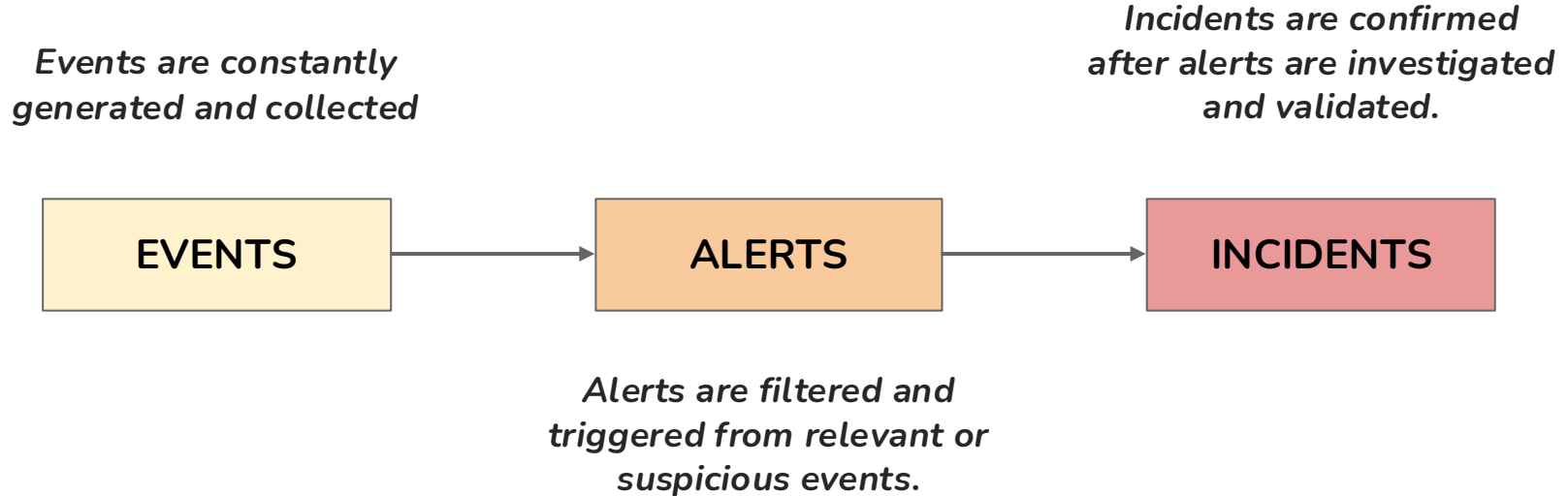
- + An **incident** is a ***confirmed*** or ***suspected*** breach of security policy or acceptable use, as determined by the analysis of alerts and associated data.
- + Examples:
 - + A ransomware attack encrypting files on multiple endpoints
 - + An attacker gaining unauthorized access to sensitive systems
 - + Exfiltration of customer *PII* data to an external server
 - + Credential theft and lateral movement within the network

Incidents

- + Key Characteristics:
 - + Incidents are actionable and require an IR response
 - + Can involve one or multiple alerts and events
 - + Must be documented, analyzed, and remediated

An incident is the confirmed threat that must be investigated, contained, and resolved.

Relationship Between Them



Relationship Between Them



Why It Matters

- *Helps focus the analyst's attention on what truly matters*
- *Prevents alert fatigue by filtering noise from signal*
- *Enables proper incident classification, escalation, and documentation*
- *Ensures efficient use of IR resources*

Thank You!

Alert Fatigue



Alert Fatigue

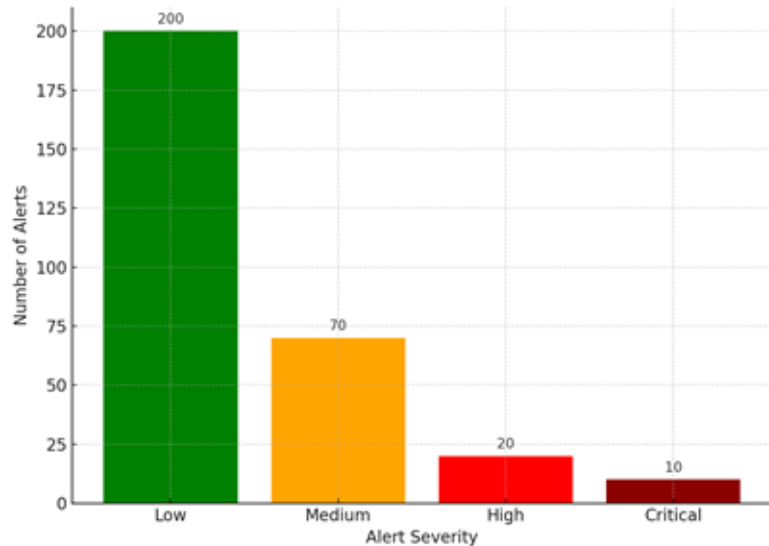
Alert Fatigue

- Alert fatigue happens when analysts are exposed to a high volume of security alerts, many of which are low-priority, repetitive, or false positives.
- Over time, this constant stream reduces attention, slows response times, and increases the risk of missing real threats.
- For a Tier 1 (L1) SOC analyst, this is especially important because you are the first line of defense.

Alert Fatigue

“Mental exhaustion”

- Caused by high volume of alerts
- Hundreds of alerts per shift
- Repeated alerts from the same host or user
- Alerts that frequently turn out to be benign
- Pressure to close tickets quickly to maintain SLAs
- Can cause analysts to become desensitized
 - Leads to missing actual threats
 - Assume an alert is “just another false positive”
 - Skim instead of fully investigating
 - Close alerts prematurely
- Common problem in all SOC's

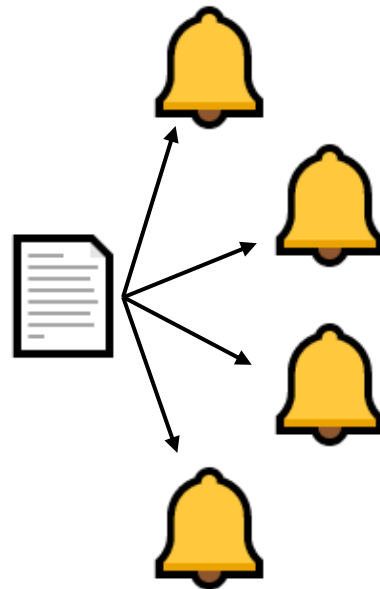


Signs and Results

- Signs of alert fatigue
 - Clicking through alerts without proper review
 - Ignoring low-priority alerts
 - Slow response times
 - Increased errors in analysis & escalation
- Results of alert fatigue
 - Missing true positives hidden among multiple false positives
 - Slower response = higher dwell time
 - Analyst turnover
 - Team morale

Root Causes

- Excessive false positives
 - Poorly tuned SIEM detection or alerting rules
- Overlapping or duplicate alerts
 - Multiple systems monitoring/alerting on same events
- Lack of automation
 - Manual triage for alerts that could be auto-enriched
- Duplicate alerts
- Improper or ineffective prioritization/severities
- Inconsistent procedures
- Low signal-to-noise ratio
 - High volume of noise (benign activity)
 - Low proportion of actionable alerts



Reducing Alert Fatigue

- Good use of severity and prioritization with alerts
- Effective use of dashboards
- Document & escalate repeated false positives
- Follow escalation workflows
 - Don't over-investigate
- Batch analysis when possible
- Senior analyst/management actions
 - Rule and alert tuning
 - Effective use of automation
 - Known benign activity suppressed

What To *Do* About It

- Don't be complacent
- Follow a structured triage process
- Document False positives clearly
- Every alert deserves attention
 - At least quick validation to ensure not serious (or is serious)
- Use available tools
 - Ticketing systems
 - Notes & KBs
- Know when to ask for help
 - For both analysis and mental health

Thank You!

Logging & Analysis Challenges



Logging & Analysis Challenges

Challenges

- Massive amounts of data handled in SOC
 - Logs, events, notes, escalations, IOCs, etc
 - SIEM, EDR, KBs, tickets
- Logs aren't always perfect
- Gaps, noise, complexity
- Overcoming challenges is part of the job

Log Information Challenges

- Log volume
 - Can be millions of logs per day
 - If raw searches needed, can be extremely difficult
 - Not always an issue for T1, but still something to be aware of
- Noise in logs
 - Separating useful information from routine, trivial data
- Incomplete/missing logs
 - Logging issues resulting in missing data
 - Systems not configured properly (or at all)
- Different formats
 - Normalization process isn't always perfect
 - different vendors = different log formats
 - T1 analysts may need to interpret different formats confidently

Log Information Challenges

- Context:
 - Logs may not tell the full story, additional info may be needed
 - ex: firewall logs showing blocking a source ip from leaving network, but no information on process or user that initiated connection
 - Requires checking other systems if SIEM doesn't perform effective correlation (or if just not working, etc)
 - Analysts may need to manually consult supplementing systems/data (EDR info, asset/user information, threat intelligence, etc)

False Positives

True positive	False positive	True negative	False Negative
Alert indicates malicious activity, and is accurate	Alert indicates malicious activity, but none actually exists	No alert generated, no malicious activity occurring	No alert generated, missed malicious activity

Poorly tuned rules → numerous low value alerts → alert fatigue

Timestamps

- Timestamps must be universally applied
 - Standardized timezone for all logs
- Incorrect time can cause missed events
 - Logs/events can appear out of order
 - Correlation rules may miss links between events
- Can be helped with time synchronization
 - NTP server(s), Active Directory, etc
 - Must still be managed and monitored
 - Sync issues can be common

Case Study: The 3-Hour Blind Spot

- It's 10:15 AM and a Tier 1 analyst is reviewing overnight alerts in the SIEM. An alert shows multiple failed logins followed by a successful login to the company's HR management system from an external IP address.
- A few minutes later, there are database queries pulling large amounts of employee data.
- The analyst checks the firewall logs to confirm the source IP and then pivots to the Windows event logs on the HR application server. But something doesn't line up.
- The firewall shows the suspicious connection at 02:12 AM, while the Windows security log shows the successful login at 05:12 AM.
- At first glance, it looks like two unrelated events.

Case Study: The 3-Hour Blind Spot

- After double-checking system settings, the analyst discovers the HR application server's clock is 3 hours ahead due to an incorrect time zone configuration. Once adjusted, the events align perfectly:
 - 02:10 AM – Multiple failed login attempts
 - 02:12 AM – Successful login
 - 02:13–02:20 AM – Large SQL queries executed
 - 02:25 AM – Outbound data transfer spike
- What initially appeared to be noise turned out to be a confirmed breach.
- The lesson: If log sources are not time-synchronized, your timeline is broken — and so is your investigation.

Analyst Mindset

- Expect imperfection
- No logs $\neq$ no activity
- Use multiple sources
- Escalate to system admins/engineers when problems appear
- **Don't be afraid to ask questions or get clarification**

Thank You!

SOC Logging & Analysis - Summary

Key Concepts - Recap

- + Logging Fundamentals
- + Event Analysis
- + SIEM Fundamentals



Learning Outcomes Recap

- + Understand the need for logs and what they provide
- + Understand where logs originate and how to collect them
- + Be able to effectively interpret and analyze simple logs
- + Properly understand and navigate a SIEM
- + Understand alerts and the alerting lifecycle
- + Be able to combat alert fatigue and other challenges

Next Steps

1. Deepen SIEM Query & Data Analysis Skills

- + Master advanced query languages:
 - + KQL (Microsoft Sentinel)
 - + SPL (Splunk)
 - + Elasticsearch DSL / Lucene
- + Build complex correlation searches
- + Develop custom dashboards for different SOC roles (L1 vs L2 vs Threat Hunting)

2. Work with Additional SIEM Platforms

- + Splunk, ELK, QRadar etc.

3. Log Source Specialization

- + Deep dive into specific log sources:
 - + Windows Event Logs (Security, Sysmon, PowerShell)
 - + Linux syslog & auditd
 - + Web server logs (Apache/Nginx)
 - + Firewall & IDS logs (Suricata/Snort)

4. Apply your skills in a lab environment (Course labs & Skill Dive)



Thank You!

EXPERTS AT MAKING YOU AN EXPERT

